bank.ly 帮客力 安全自评报告

2026 深圳国际金融科技大赛（FinTechathon）

人工智能赛道

Team SKS

GitHub 仓库：github.com/fvia88/ai-banking-agent

1 评估范围与安全架构

bank.ly 帮客力使用模拟银行数据展示对话式余额查询、支出分析、转账和订阅管理。本报告评估权限分级、执行保护、模型边界、审计覆盖和共享评审部署条件，属于项目自评，不是独立安全认证。

模型只提出结构化操作，不能直接转移资金或修改订阅。确定性策略引擎结合后端确定的上下文评估提案，审批、验证挑战、数据库事务和执行结果由后端负责。

安全职责

工程角色	职责
智能体工程	意图校验、可信上下文匹配、关联工具结果、安全失败回复及受控续接。
后端工程	身份范围、审批绑定、执行检查、事务保护、持久化和审计。
安全工程	默认拒绝的策略评估、权限规则、安全锁及对抗检查。
财务工程	确定性财务计算，并与后端协同实现验证挑战。
订阅工程	周期扣款检测、已存记录映射与取消资格。

授权边界

`evaluate_action(proposal, context, config)` 为纯策略函数，无 I/O、不修改输入，对无效输入或意外策略错误返回拒绝。后端默认使用真实安全适配器，模拟安全需明确配置。共享部署入口要求真实智能体、安全及订阅适配器。

第2-3节说明授权与执行，第4-5节说明模型、部署保护及验证证据。

实现位置： `security/policy.py`、`security/rules.py`、`backend/app/services/adapters.py`、`infra/start_shared.py`。

2 权限分级与输入校验

权限分级实现

等级	适用操作	控制要求
GREEN	余额、支出、周期扣款查询。	校验工具参数与账户范围后自动读取。
YELLOW	订阅取消；当日已完成转账加本次金额不超过 1,000.00 元。	明确确认已存的具体提案。
RED	上述累计超过 1,000.00 元的转账。	明确确认后进行模拟 MFA。
拒绝	输入、工具、参数错误，账户不符，锁定账户的禁止操作或策略内部错误。	`allowed_to_proceed=False`，不执行财务操作。

RED 标签本身不代表可执行。后端必须检查 `allowed_to_proceed` 并落实确认和验证要求。订阅取消始终需要确认。

默认拒绝的评估顺序

步骤	检查	结果
1	要求 `ActionProposal` 与 `BankingContext` 对象。	无效则 `INVALID_PROPOSAL` 或 `INVALID_CONTEXT`。
2	工具须属于 `contracts.enums.ToolName`。	否则 `UNKNOWN_TOOL`。
3	按标准结构执行 `validate_tool_arguments`。	无效则 `INVALID_TOOL_ARGUMENTS`。
4	变更操作检查 `account_locked`，读取可按配置检查。	锁定则 `ACCOUNT_LOCKED`。
5	将 `source_account_id` 或查询 `account_id` 与上下文比较。	不符则 `SOURCE_ACCOUNT_MISMATCH` 或 `ACCOUNT_MISMATCH`。
6	Decimal 计算当日已完成金额加请求金额。	返回适用等级及控制要求。
保护	捕获意外策略异常。	返回 `INTERNAL_POLICY_ERROR` 并拒绝。

策略异常不降级为允许；默认安全锁策略保留只读访问。

标准参数控制

输入	校验
金额	正数 Decimal，最多两位小数、16 位总数字；拒绝零、负数、非有限值和过高精度。
币种	精确支持值 `CNY`。
标识符	非空有界 ID，最多 128 字符。
额外字段	拒绝未知字段及 `bypass_mfa`、`admin` 等越权尝试。
审批元数据	`action_id`、摘要与等级不混入财务工具参数。

提案理由不决定授权或等级；收款人与订阅根据已验证后端上下文匹配，不接受模型编造的身份。

决策字段与原因码

GREEN 返回 `READ_ONLY_ACCESS`，无需确认或 MFA；YELLOW 转账为 `TRANSFER_WITHIN_DAILY_LIMIT`，订阅取消为 `SUBSCRIPTION_CANCEL_CONFIRMATION_REQUIRED`。RED 转账为 `TRANSFER_EXCEEDS_DAILY_LIMIT`，要求确认及 MFA。拒绝独立设置 `allowed_to_proceed=False`。

明确拒绝负数、零及负零、`100.999` 等不足分位精度、超位数值、`NaN` 和 `Inf`；拒绝不支持币种及大小写、空格变体，拒绝空值或超长 ID。`mfa_verified`、`force_immediate`、`user_id`、`action_digest`、`tier` 等不能插入工具参数以改变权限。

实现位置： `contracts/models.py`、`contracts/tool_schemas.py`、`security/policy.py`、`backend/app/services/actions.py`。

运行时账户检查与适配器

转账要求 `source_account_id`，创建操作前与后端账户核对；读取要求 `account_id`，聊天路由在查询前校验并调用策略。默认策略下锁定用户可进行获准读取。

确认与验证时，从已存标准载荷重建提案，校验摘要、刷新当前用户和账户并再次评估策略。正确 OTP 不能覆盖当前拒绝；提案后新产生的锁仍阻止执行。

适配器默认调用 `security.policy.evaluate_action`。构造参数只接受布尔值或 `None`；环境变量 `USE_MOCK_SECURITY` 默认 `false`，只接受不区分大小写的 `true`、`false`。错误配置报错，不静默启用宽松适配器。显式模拟仅用于隔离开发，不改变默认授权路径。

运行时验收条件

条件	必须行为
账户 ID 与上下文不符	读取或创建可执行操作前拒绝。
提案后账户锁定	确认或验证时拒绝。
已存载荷修改	摘要或参数校验阻止执行。
提案后日累计变化	重新评估，必要时升级。
OTP 正确但策略拒绝	不执行。
重复确认已完成操作	返回已有结果，不再次扣款。

实现位置： `backend/app/services/adapters.py`、`actions.py`、`backend/app/api/chat.py`、`approvals.py`、`backend/tests/test_security_bridge.py`、`test_security_integration.py`。

3 审批、MFA 与事务安全

提案绑定审批

后端保存标准工具参数，对工具及排序后的 JSON 载荷计算 SHA-256。确认须对应所属票据和摘要。摘要绑定已批准载荷，不是数字签名或身份认证替代。

执行前从存储重建提案，检查完整性、归属、锁、余额、订阅资格及当前等级。另一笔转账改变日累计后，先前 YELLOW 可升级为 RED；原 RED 不降级。

验证生命周期与安全锁

RED 确认生成绑定操作和所有者的随机六位挑战，有效期最多 5 分钟且不超过 10 分钟票据期限。过期、已消费或未签发挑战不能授权；验证成功在执行保护内有条件消费挑战。

15 分钟内三次错误验证码或篡改确认触发持久化用户锁。转账和取消被阻止，其他待审批终止，只读保留。本地操作员重置须填写复核原因并记审计。

并发请求与财务一致性

场景	控制
同票据重复确认	数据库保护下认领操作，完成后重放结果，不重复执行。
竞争转账跨日限额	串行保护账户更新，按最新累计重评并升级 MFA。
竞争转账超可用资金	保护内检查余额，失败回滚部分写入。
确认与验证同时到达	操作状态和条件消费挑战协调执行。
午夜后首批转账	按 Asia/Shanghai 日期在保护内滚动计数。

按用户、操作、账户顺序获取数据库保护。PostgreSQL 行保护和 SQLite 写串行化支持事务边界。余额、账本、审计与操作终态一起提交，失败回滚。

撤销与依赖任务

未执行审批（含待 MFA）可撤销，不改余额或订阅。取消草稿不逆转已完成转账。可信完成后才推进依赖步骤；失败、拒绝或撤销停止后续任务，每个新操作独立授权。

实现位置： `backend/app/services/action_execution.py`、`daily_transfers.py`、`mfa.py`、`safety_lock.py`、`backend/app/api/approvals.py`、`agent/planning.py`。

并发回归场景

原评估记录以下文件型 SQLite 检查通过；它们是已记录行为，不是此次文档更新的新测试。PostgreSQL 变体需独立环境。

场景	机制与记录结果
同 YELLOW 票据并发确认	受保护认领和终态检查使其只有一笔转账账本和一次执行审计；竞争请求获得已有结果或冲突。
两笔 600 元竞争日阈值	首笔完成后累计为 600.00，第二笔使累计超过 1,000.00，升级 `PENDING_MFA`，验证前不转出。
竞争转账超余额	账户保护和即时资金检查仅允许可负担操作；拒绝则回滚并记录失败，无额外扣款。
RED 并发验证	条件消费挑战和受保护更新防止已验证操作竞争导致透支。
上海新银行日首批请求	保护内仅重置一次日累计，记录 `DAILY_TRANSFER_TOTAL_RESET`，计算新日已完成转账。

事务与重放边界

执行保护将即时授权、余额、账本、审计和状态协调在受控事务内。PostgreSQL 使用行保护，SQLite 使用其写串行化；不能把 SQLite 测试当作 PostgreSQL 行锁证据。

单次财务效果保证绑定特定服务器操作及生命周期。独立提案是不同操作，仍需当前累计、资金及审批检查。恢复完成回复不授权另一笔转账。

回归测试： `backend/tests/test_security_concurrency.py` 中的 `test_same_yellow_action_cannot_execute_twice`、`test_competing_yellow_actions_cannot_bypass_cumulative_mfa`、`test_competing_yellow_actions_cannot_overspend_account`、`test_competing_red_verifications_cannot_overspend_account`、`test_first_concurrent_transfers_of_new_day_reset_once`。

4 模型边界、访问保护与审计

模型与工具保护

威胁	处理
编造余额或完成	报告前关联已存提案、参数、账户和期间。
理由、商户、备注注入	外部文本视为数据，强制结构及工具白名单，不以理由授权。
模型故障或错误格式	限时请求、分类安全回复，失败不生成提案。
未授权账户选择	后端确定范围，云端固定模拟身份。
模型生成可执行代码	仅接受结构化提案，不运行生成脚本、Shell 或任意 Python。

类型化白名单是执行边界，不是任意代码的操作系统沙箱；任意生成代码不进入执行路径。

共享部署访问

Render 通过 HTTPS 提供前后端；HTTP Basic 网关保护网站与 API，仅最小健康端点例外。忽略客户端自选身份头，固定 `usr_demo_01`，检查浏览器来源，并采用进程级请求及写入限流。

Groq 密钥、连接串和演示密码为 Render 私有环境配置，不嵌入前端或本文。Neon 独立持久化数据，评审只获取演示网址及另行提供的访问凭据。

审计事件覆盖

事件组	类型
财务执行	`TRANSFER_EXECUTED_ATOMIC`、`SUBSCRIPTION_CANCELLED`
策略	`ACTION_POLICY_REJECTED`、`ESCALATED_TO_RED`
验证	`MFA_CHALLENGE_ISSUED`、`VERIFICATION_FAILURE`
审批生命周期	`APPROVAL_CANCELLED_BY_USER`、`ACTION_STATUS_OBSERVED`
安全锁	`SAFETY_LOCK_TRIGGERED`、`SAFETY_LOCK_RESET`、`ACTION_REJECTED_SAFETY_LOCK`
跨日	`DAILY_TRANSFER_TOTAL_RESET`

提供器失败日志含事件 ID、阶段、安全分类及可选 HTTP 状态。财务结果确定性计算，不由模型生成。审计是后端操作和安全事件，不等于完整模型推理或全部读取授权记录。

应用采用追加式审计模式，但普通记录不具数据库强制或密码学不可变性。初始提案保存审批记录但无对应审计；读取授权未完整记录，计划暂停、停止和人工移交也不是完整审计流程。这些区别界定当前证据覆盖。

实现位置： `infra/shared_app.py`、`agent/service.py`、`agent/request_guard.py`、`backend/app/services/audit.py`、`backend/app/api/continuation.py`。

5 验证证据与运行条件

已记录安全检查

以下来自原工程评估，是对应环境证据，不代表新运行或当前全库统计。各行存在包含关系，不可相加为唯一测试数。

测试集	记录结果	覆盖
`security/tests/test_policy.py`	84 通过	策略、精确阈值、夹具和对抗输入。
`backend/tests/test_security_bridge.py`	27 通过	默认真实适配器、配置、HTTP 桥接。
`backend/tests/test_security_integration.py`	16 通过	即时策略、升级、完整性和锁。
`backend/tests/test_security_concurrency.py`	6 通过；6 个 PostgreSQL 变体未执行	SQLite 重复执行、阈值、透支和跨日。
`backend/tests/test_mfa.py`	18 通过	挑战、次数限制、同操作执行保护。
`tests/test_contracts.py`	14 通过	共享模型与夹具。
合并 `backend/tests`	238 通过；22 个 PostgreSQL 相关未执行	原评估的更广后端结果，包含上方测试集。

证据支持所记录 SQLite 检查。PostgreSQL 并发和负载行为需独立可丢弃测试库，仅部署 Neon 不证明这些结果。

复现安全测试

在仓库根目录用已安装的项目 Python 环境运行。需数据库管理权限的测试只使用可丢弃库，不将破坏性迁移或竞态测试指向云端演示库。

```
$env:PYTHONPATH = 'backend;.;contracts'
python -m pytest security/tests/test_policy.py -v
python -m pytest backend/tests/test_security_bridge.py -v
python -m pytest backend/tests/test_security_integration.py -v
python -m pytest backend/tests/test_security_concurrency.py -v
python -m pytest backend/tests/test_mfa.py -v
python -m pytest tests/test_contracts.py -v
```

PostgreSQL 变体使用 `MIGRATION_TEST_POSTGRES_ADMIN_URL`。SQLite 通过记录覆盖重复执行、日累计升级、资金不足保护和跨日，不证明 PostgreSQL 负载并发。

评估结论

bank.ly 帮客力将语言理解与授权、执行分离。记录测试支持所述演示环境中的默认拒绝策略、结构校验、操作绑定审批、模拟 MFA、安全锁和受保护财务更新。本评估支持受控的模拟竞赛演示，不构成生产银行就绪认证。

仓库支持材料

参见安全文档、技术实现及共享部署说明。所列测试可复现检查。评审凭据私下提供，本文不含实际密码、API 密钥或数据库凭据。